

# Acme Corporation Legal and Compliance Manual

Policy Manual — Edition 2023

## 1. Data Retention

Customer personal data is retained for the duration of the contract plus 90 days. Backups are retained for 35 days on a rolling basis. Financial records are retained for 7 years in accordance with statutory requirements. Deletion requests from data subjects must be fulfilled within 30 days.

A new data classification framework is introduced with four tiers: Public, Internal, Confidential, and Restricted. Each tier has defined handling, storage, and destruction requirements.

## 2. GDPR Compliance

Acme processes personal data of EU residents under the lawful bases of contract performance, legitimate interest, and consent. The Data Protection Officer can be reached at [dpo@acmecorp.example](mailto:dpo@acmecorp.example). Data Processing Agreements are required with all sub-processors. Cross-border transfers rely on Standard Contractual Clauses and, where applicable, the EU-US Data Privacy Framework.

## 3. CCPA and CPRA Compliance

California residents have additional rights under CPRA, including the right to correct inaccurate personal information and the right to limit the use of sensitive personal information. Acme does not sell or share personal information.

## 4. Incident Response

Security incidents must be reported to the Security Team within 1 hour of discovery. Confirmed personal data breaches must be reported to the relevant supervisory authority within 72 hours. Affected data subjects must be notified without undue delay if the breach poses a high risk to their rights and freedoms.

A new incident severity matrix defines Sev-1 through Sev-4 incidents with corresponding response times and escalation paths.

## 5. Acceptable Use

Company systems may not be used for personal commercial activity, cryptocurrency mining, or the storage of illegal content. Personal use of email and internet is permitted within reasonable limits. All company devices must have full-disk encryption and automatic screen lock enabled.

## **6. Vendor Management**

All vendors with access to customer data must undergo a security review before onboarding and annually thereafter. Vendors must provide SOC 2 Type II reports or equivalent. Contracts must include data protection, confidentiality, and breach notification clauses.

A new vendor risk scoring model is introduced. Vendors are scored from 1 (low risk) to 5 (critical risk). Critical vendors require quarterly reviews and continuous monitoring.

## **7. AI and Machine Learning Governance**

Any use of AI or machine learning models that process personal data must be reviewed by the Legal team. Model training data must be documented. Outputs must not be used to make automated decisions affecting individual rights without human review.